

Cisco Secure Workload - NY DFS Part 500 Compliance Report

Cisco Secure Workload - NY DFS Part 500 Compliance Report

Customer-Facing Compliance Report

Framework: NY DFS 23 NYCRR Part 500 (Second Amendment, effective 1 November 2023)

Primary audience: Covered entities under 23 NYCRR Part 500 (banks, insurance companies, licensed lenders, money transmitters, virtual-currency businesses, etc.); the CISO designated under Section 500.4, risk and audit leaders, and compliance teams preparing the annual notice of compliance.

CSW positioning: Covered workload visibility, NPI segmentation, access privilege evidence, monitoring, vulnerability management, audit trail, and incident scoping.

Framework Version Note

References 23 NYCRR Part 500 as amended in November 2023. Several requirements have phased transition dates through 2024-2025 (e.g. Sections 500.7, 500.13, 500.14, 500.15, 500.17). Validate the applicable effective date for each requirement against the DFS published rule.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-NYDFS-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

NYDFS-500

- └ Covered-Systems (Customer-Channels, Account-and-Ledger, Payments-and-Settlement, Underwriting-Claims)
- └ NPI-Applications (Customer-Data-Stores, Analytics-on-NPI)
- └ Critical-Operations (Identity-Adjacent, Monitoring, Patch-Management)
- └ Third-Party-Service-Providers

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Section 500.2 - Cybersecurity Program (technical inputs)
- Section 500.5 - Vulnerability Management (CVE + reachability)
- Section 500.6 - Audit Trail (workload network layer)
- Section 500.7 - Access Privileges and Management (workload-to-workload)
- Section 500.13 - Asset Management and Data Retention (workload inventory)
- Section 500.14 - Monitoring and Training (technical monitoring)
- Section 500.16 - Incident Response (forensic timeline)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Section 500.3 - Cybersecurity Policy (governance)
- Section 500.4 - CISO role
- Section 500.12 - MFA (identity layer)
- Section 500.15 - Encryption (CSW detects plaintext flows but does not enforce encryption)
- Section 500.17(a) - 72-hour notification decision (CSW provides scoping inputs only)

- Section 500.17(b) - Annual notice of compliance / senior officer certification (governance)

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Section 500.2 - Program operation	Direct	Continuous workload telemetry + periodic evidence pack	Quarterly evidence bundle demonstrating program operating across covered workloads
Section 500.5 - Vulnerability management	Direct	Reachability-weighted CVE evidence	Prioritised remediation list with compensating controls
Section 500.6 - Audit trail	Direct	Workload flow + process telemetry retained per retention policy	Retained flow telemetry for audit-trail purposes
Section 500.7 - Access privileges	Direct	Policy workspace + enforcement / violation log	Workspace snapshot and least-privilege evidence at workload-to-workload layer
Section 500.13 - Asset management	Direct	Workload inventory; scope + label export	Inventory and classification evidence
Section 500.14 - Monitoring	Direct	Continuous flow + process telemetry; alerts	Monitoring evidence at network and process layer
Section 500.15 - Encryption (detection)	Supporting	Plaintext-flow detection on regulated paths	Detection input only - encryption itself is enforced elsewhere
Section 500.16 - Incident response	Direct	Forensic flow + process search	Incident timeline and impact scope
Section 500.17(a) - Notification scoping	Supporting	Affected-systems list with time windows and paths	Scoping input to the 72-hour notification decision

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Covered workload inventory	Information systems in scope of Part 500	Inventory + scope membership export	Monthly
NPI scope evidence	Workloads handling nonpublic information	Scope + label export filtered by data_class=npi	Monthly
Audit-trail retention	Workload flow + process telemetry for the required window	Retained telemetry export	Continuous, validated quarterly
Least-privilege evidence	Workspace snapshot and policy violation log	Policy workspace export and policy analysis output	Quarterly + after each change
Vulnerability + reachability	CVE list weighted by reach into NPI-Applications and Covered-Systems	Vulnerability report scoped to NYDFS-500	Monthly
Third-party egress reconciliation	Outbound flow to vendor endpoints	Flow search filtered to vendor endpoints	Monthly
Incident timeline sample	One representative incident	Flow + process search	Per incident; one representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, npi, cui, ephi).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace the CISO function, written policies, MFA / IAM enforcement, encryption programmes, the risk assessment itself, the 72-hour notification decision under Section 500.17(a), or the senior officer / board-of-directors annual notice of compliance under Section 500.17(b).

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.